Môn: Điện Toán Đám Mây
Mã lớp học phần: 012012303904

Thiết kế và kiểm chứng kế hoạch phục hồi sau thảm họa cho ứng dụng cloud native

Người trình bày:
Hoàng Việt Quang-066206005044
Nguyễn Minh Thư-082306008557
Lê Thị Lan Hương-052306007313

Kiến trúc: một cụm chạy, ba nơi giữ bản sao

Cụm chính

K3s trên Azure, Hàn Quốc
web, API, PostgreSQL

Kho sao lưu ở Nhật

WAL, base backup, Velero, bản chép ảnh

Cụm dự phòng

Hàn Quốc; chạy sẵn khi dùng cách ấm

Két chống xóa ở Nhật

WORM 7 ngày, gói mã hóa bằng age

Server ngoài Azure

Kéo gói từ két mỗi đêm qua Tailscale

Đổi máy chủ cho tên miền API bằng Cloudflare DNS (TTL 60 s). Mã nguồn và image nằm trên GitHub, ngoài Azure.

Kế hoạch trên giấy có đạt RTO, RPO thật không?

Câu hỏi nghiên cứu: một kế hoạch chưa từng được diễn tập thì chưa biết có khôi phục kịp hay không. Nhóm đặt mục tiêu, dựng hệ thống, rồi phá thật và đo.

60 phút

RTO cách lạnh: dựng cụm mới từ bản sao lưu

10 phút

RTO cách ấm: chuyển sang cụm dự phòng đang chạy

5 phút

RPO bài viết và ảnh: dữ liệu mất tối đa

RTO (recovery time objective): thời gian tối đa được phép ngừng. RPO (recovery point objective): lượng dữ liệu tối đa được phép mất, tính theo thời gian.

Đánh giá ảnh hưởng nghiệp vụ (Business Impact Analysis - BIA)

BIA là bước cốt lõi trong quy trình lập kế hoạch dự phòng hệ thống thông tin. BIA giúp xác định, phân loại và ưu tiên các quy trình nghiệp vụ quan trọng của tổ chức, từ đó đánh giá mức độ ảnh hưởng và thiệt hại khi ứng dụng hoặc tài nguyên hệ thống bị gián đoạn.

Các bước thực hiện BIA:

- Xác định quy trình nghiệp vụ và mức độ quan trọng: Liên kết ứng dụng với các quy trình nghiệp vụ cốt lõi và đo lường mức độ thiệt hại (tài chính, pháp lý, uy tín) nếu xảy ra sự cố.
- Xác định yêu cầu tài nguyên: Liệt kê đầy đủ các tài nguyên phụ thuộc (máy chủ, dữ liệu, phần mềm, kết nối mạng) cần thiết để khôi phục nghiệp vụ.
- Thiết lập thứ tự ưu tiên khôi phục: Sắp xếp thứ tự phục hồi cho các thành phần hệ thống dựa trên mức độ ảnh hưởng nghiệp vụ.

Phân tích ảnh hưởng nghiệp vụ

Thành phần	Nếu mất thì	RPO	RTO lạnh / ấm
Cơ sở dữ liệu bài viết	Không đọc, không đăng được bài	5 phút	15 phút / 2 phút
Kho ảnh	Bài hiện mà ảnh lỗi	5 phút	15 phút / 2 phút
Cấu hình triển khai	Không dựng lại được dịch vụ	1 giờ	15 phút / có sẵn
Cả trang web	Người dùng không vào được	5 phút	60 phút / 10 phút

RPO 5 phút dựa vào nhật ký thay đổi (WAL) đẩy đi tối đa mỗi phút và việc Azure tự chép ảnh (đo được p95 129 s).

Nguyên tắc sao lưu dữ liệu an toàn

Sao lưu nhất quán ở mức ứng dụng (Application-Consistent Backup): là phương pháp sao lưu nâng cao, hệ thống không chỉ chụp lại các file trên đĩa cứng mà còn phối hợp trực tiếp với ứng dụng để đảm bảo toàn bộ dữ liệu trong bộ nhớ RAM và các giao dịch đang xử lý dở dang được hoàn tất và ghi xuống đĩa an toàn trước khi tiến hành sao lưu

Snapshot nhất quán của cơ sở dữ liệu (Database-Consistent Snapshot): là bản chụp nhanh toàn bộ dữ liệu của CSDL, tại một mốc thời điểm chính xác, đảm bảo mọi giao dịch, bảng dữ liệu, chỉ mục (indexes) và nhật ký giao dịch (transaction logs) hoàn toàn khớp nhau và không bị dở dang

Bản sao lưu không thể sửa, xóa (Immutable Backup / Immutability): là cơ chế bảo vệ dữ liệu sao lưu theo nguyên tắc WORM (Write Once, Read Many). Sau khi bản sao lưu được tạo ra, nó bị "khóa" hoàn toàn — không bất kỳ ai (kể cả tài khoản quản trị cao nhất như Admin/Root) có thể chỉnh sửa, ghi đè hoặc xóa bản sao lưu đó trong suốt khoảng thời gian lưu giữ (Retention Period) đã thiết lập

Mã hóa bản sao lưu (Backup Encryption): là quá trình chuyển đổi toàn bộ dữ liệu sao lưu từ dạng văn bản rõ (Plaintext) sang dạng mật mã bí ẩn (Ciphertext) bằng các thuật toán mã hóa tiêu chuẩn (như AES-256). Khi đã được mã hóa, nếu không có "chìa khóa giải mã" (Decryption Key) hợp lệ, bất kỳ ai lấy được tệp sao lưu cũng chỉ nhìn thấy một chuỗi ký tự vô nghĩa và không thể xem hay trích xuất được thông tin bên trong.

Quy tắc sao lưu 3-2-1 (3-2-1 Backup Rule)

Quy tắc 3-2-1 là nguyên tắc kinh điển và tiêu chuẩn vàng trong thiết kế hệ thống an toàn dữ liệu và phòng chống mất mát dữ liệu và khôi phục hệ thống sau thảm họa.

- 3 Bản sao dữ liệu (3 Copies of Data): Duy trì ít nhất 1 bản dữ liệu gốc đang chạy (Primary Production Data) và 2 bản sao lưu độc lập (Backup copies).
- 2 Loại phương tiện lưu trữ khác nhau (2 Different Media Types): Lưu trữ dữ liệu trên 2 dạng/vùng lưu trữ tách biệt (ví dụ: Persistent Volume snapshot trên Block Storage và bản lưu file nén trên Object Storage) để tránh lỗi đơn điểm phần cứng (Single Point of Failure).
- 1 Bản sao lưu ở vị trí khác (1 Offsite Copy): Đặt ít nhất 1 bản sao lưu tại một vị trí địa lý độc lập (Offsite Storage / Vùng đám mây khác - Multi-Region) nhằm đảm bảo dữ liệu an toàn nếu toàn bộ trung tâm dữ liệu chính bị thảm họa thiên tai hoặc mất điện diện rộng.

Sao lưu ba tầng theo quy tắc 3-2-1

1

Kho sao lưu ở Nhật

• WAL đẩy liên tục, tối đa mỗi phút
• Base backup và Velero mỗi giờ
• Ảnh được Azure tự chép sang Nhật

Khôi phục hằng ngày

2

Két chống xóa

• Chính sách WORM 7 ngày, đã khóa cứng
• Gói mã hóa bằng age trước khi rời cụm
• Không ai xóa được, kể cả chủ tài khoản

Chống mã độc tống tiền

3

Server ngoài Azure

• Tự kéo gói từ két mỗi đêm
• Không giữ khóa giải mã
• Dùng khi mất cả tài khoản Azure

Chống mất nhà cung cấp

Đo từng bước, không đoán

Phát hiện

Quyết định

Dựng hạ tầng

Khôi phục dữ liệu

Kiểm tra

Đổi DNS

- Công cụ azure_drill gọi /healthz mỗi giây và ghi mốc thời gian của từng bước vào CSV.
- Sau khôi phục: so số bài viết, băm SHA-256 từng ảnh, đăng thử một bài mới.
- Bài và ảnh mất được so với RPO; lần nào thiếu dữ liệu ngoài RPO là không đạt.

Các chiến lược dự phòng(DR Strategies)

Pilot Light (Đèn báo sự cố / Môi trường chờ tối thiểu)
chỉ các thành phần dữ liệu cốt lõi (như cơ sở dữ liệu) được duy trì chạy liên tục ở môi trường dự phòng và đồng bộ dữ liệu ngầm (Asynchronous Replication). Các thành phần tính toán, ứng dụng (App/Web servers, Kubernetes worker nodes) chỉ tồn tại dưới dạng cấu hình/kịch bản tự động hóa và chỉ được khởi tạo, mở rộng (scale-out) khi thảm họa xảy ra.

Active-Active (Song song Hoạt động)
là chiến lược Phục hồi Thảm họa ở cấp độ cao nhất trong điện toán đám mây và hệ thống thông tin. Có hai hoặc nhiều môi trường/trung tâm dữ liệu cùng hoạt động song song thời gian thực cùng ở trạng thái hoạt động (Active) 24/7 , tự động phân chia tải lưu lượng người dùng. Dữ liệu được đồng bộ tức thì hai chiều giữa các vùng bằng cơ chế đồng bộ trực tiếp để đảm bảo tính đồng nhất tuyệt đối tại mọi thời điểm.

Active-Passive (Mô hình Hoạt động - Chờ)
môi trường chính (Active Site) xử lý 100% lưu lượng người dùng, trong khi môi trường dự phòng (Passive Site) ở trạng thái chờ trang này liên tục hoặc định kỳ nhận dữ liệu đồng bộ (Replication) từ trang Active để sẵn sàng thay thế khi có sự cố xảy ra. Ở môi trường chờ (passive) có 3 cấp độ chờ:

- Cold Passive
- Warm Passive
- Hot Standby

Warm Standby (Môi trường dự phòng thu nhỏ)
duy trì một phiên bản thu nhỏ (scaled-down version) của toàn bộ hệ thống/ứng dụng chạy song song tại trung tâm dữ liệu dự phòng. Một phần hạ tầng luôn ở trạng thái hoạt động (Active) và sẵn sàng tự động mở rộng (Auto-scaling) để gánh toàn bộ lưu lượng khi môi trường chính gặp sự cố.

So sánh chi phí để duy trì

Chiến lược dự phòng	RTO (Thời gian khôi phục)	RPO (Mức mất dữ liệu)	Mức độ phức tạp	Chi phí vận hành
Pilot Light	Vài chục phút	Vài giây - Phút	Trung bình	Mức thấp
Warm Standby	Vài chục phút	≈0(vài giây)	Khá cao	Mức trung bình
Active-Passive	Vài phút - Vài giây	Gần bằng 0	cao	Cao
Active-Active	≈0(Tức thì)	0 (Zero Data Loss)	Cực kỳ phức tạp	Cao nhất

Các phương án khôi phục

Tình huống	Phương án	Lệnh chính thức thực hiện
Mất namespace dr-api	Khôi phục tại chỗ về 1 giây trước sự cố từ bản sao lưu	restore-namespace.sh
Mất máy chính, chưa có cụm dự phòng ấm	Chuyển đổi dự phòng ấm	failover-cold.sh
Mất máy chính, đang có cụm dự phòng ấm đã chạy	Chuyển đổi dự phòng ấm	failover-warm.sh
Mất toàn bộ nhóm rg-dr-primary	Dựng cụm mới (chuyển lạnh) hoặc khôi phục từ bản sao lưu (chuyển ấm), chỉ có dự phòng lạnh mới truyền thêm biến DR_IMAGES_FROM_COPY=true	failover-cold.sh failover-warm.sh

Đánh giá kiểm chứng hiệu quả khôi phục

Tình huống	RTO	RPO
Mất namespace	64 giây	Theo bản sao lưu gần nhất
Mất máy chính, chưa có cụm dự phòng ấm	60 phút	5 phút
Mất máy chính, đang có cụm dự phòng ấm	10 phút	5 phút
Mất toàn bộ nhóm tài nguyên chính	60 phút	5 phút đối với ảnh và dữ liệu

Các vòng diễn tập thử

Mã diễn tập	Tình huống	RTO	RPO	Kết quả	Lý do
Trial-D1-1	Mất namespace, khôi phục tại chỗ	Không đo được	Không đo được	Không đạt	Không tìm thấy bản sao lưu phù hợp.
Trial-D1-2	Mất namespace, khôi phục tại chỗ			Không đạt	Lỗi cú pháp json xử lý khi chọn bản sao lưu
Trial-D1-3	Mất namespace, khôi phục tại chỗ	74,0 giây	4,158 giây	Đạt	
Trial-D2-1	Mất máy chính, chuyển dự phòng lạnh			Không đạt	Máy ảo Azure bị kẹt ở trạng thái starting
Trial-D2-2	Mất máy chính, chuyển dự phòng lạnh	416,5 giây	6,396 giây	Không đạt	Kiểm tra phát hiện bị lỗi không ghi được ảnh
Trial-D2-3	Mất máy chính, chuyển dự phòng lạnh	433,6 giây	42,75 giây	Không đạt	50 ảnh không được sao chép sang kho lưu trữ ảnh dự phòng
Trial-D2-4	Mất máy chính, chuyển dự phòng lạnh	451,5 giây	41,636 giây	Đạt	

Các vòng diễn tập thử

Mã diễn tập	Tình huống	RTO	RPO	Kết quả	Lý do
Trial-D3-1	Mất máy chính, chuyển dự phòng ấm	247,2 giây	19,54 giây	Đạt	
Trial-D4-1	Mất toàn bộ nhóm tài nguyên			Không đạt	Lỗi quá trình sao chép ảnh không kết thúc
Trial-D4-2	Mất toàn bộ nhóm tài nguyên			Không đạt	Bị ràng buộc bởi chính sách sao chép cũ, lỗi sao chép ảnh vào kho dự phòng bị từ chối
Trial-D4-3	Mất toàn bộ nhóm tài nguyên	588,4 giây	18,1 giây	Đạt (đạt khi chấm lại)	Quá trình kiểm tra ban đầu phát hiện 16 ảnh không tải được. Sau khi phân tích, xác định các ảnh này thuộc những bài đăng cũ hơn khoảng thời gian RPO 5 phút, không phải dữ liệu ảnh bị mất trong phạm vi RPO của sự cố.
Trial-D5-1	Mất toàn bộ nhóm tài nguyên (ấm)	262,3 giây	47,001 giây	Đạt	Kiểm tra phát hiện bị lỗi không ghi được ảnh

Chi phí thực hiện và vận hành của dự án

Chi phí sẵn sàng theo chiến lược (giả sử web chạy thật cả tháng / 730 giờ)

- Cách lạnh (Chỉ lưu trữ bản sao lưu): Khoảng 1 USD / tháng.
- Cách ấm (Cụm dự phòng chạy suốt gồm máy, ổ đĩa, IP và lưu trữ): Khoảng 44 USD / tháng.
- Tiêu chí lựa chọn: Dựa trên phân tích BIA (Business Impact Analysis). Nếu thiệt hại khi website ngừng hoạt động trong 1 giờ lớn hơn 44 USD/tháng, nên chọn cách ấm; ngược lại chọn cách lạnh.

Chi phí ước tính chi tiết cho đợt chạy/thử nghiệm

Thành phần	Đơn giá	Lượng ước tính	Thành tiền
Máy ảo cho cụm (B2als v2 - 2 nhân, 4 GB	0,0468/giờ	120 giờ-cụm	5,6 USD
Ổ đĩa hệ điều hành P4 (32 GB)	5,28 / tháng ≈ 0,0072 / giờ	120 giờ-cụm	0,9 USD
Địa chỉ IP công khai cho mỗi cụm	0,005/giờ	120 giờ	0,6 USD
Lưu trữ Blob	0,02/GB-tháng	khoảng 20GB x 2 tháng	0,8 USD
Thao tác ghi Blob	0,05 / 10.000 lần	khoảng 200.000 lần	1,0 USD
DNS			Sử dụng Cloudflare Free (0 USD)
Truyền dữ liệu Hàn Quốc → Nhật (WAL, ảnh)	0,08 / GB	khoảng 10GB	0,8 USD
Dữ liệu ra internet (GitHub tải bản sao lưu mỗi ngày)	100 GB đầu mỗi tháng miễn phí, sau đó 0,12 / GB	15 GB / tháng	0 USD